

Fase 3

Este plan define cómo la academia debe actuar ante los hallazgos de las Fases 1 y 2.

Preparación

- **Inventario de Activos:** Identificación de servidores Debian, bases de datos MariaDB y servicios Apache como críticos.
- **Capacitación:** Entrenamiento técnico para evitar configuraciones inseguras como el acceso FTP anónimo.

Detección y Análisis

- **Fuentes de Alerta:** Monitoreo constante de journalctl para detectar intentos de fuerza bruta en SSH.
- **Análisis Forense:** Revisión del historial de comandos (.bash_history) para identificar manipulaciones de permisos.

Contención, Erradicación y Recuperación

- **Contención Inmediata:** Deshabilitar el acceso root en SSH y detener el servicio FTP inseguro.
- **Erradicación:** Parchear vulnerabilidades críticas como CVE-2024-6387 y corregir permisos de archivos sensibles como wp-config.php a 600.
- **Recuperación:** Verificación de la integridad del sitio web y restauración de servicios bajo configuraciones reforzadas.

Sistema de Gestión de Seguridad (SGSI - ISO 27001)

Establecer controles preventivos para que estos incidentes no se repitan.

Políticas de Seguridad Requeridas:

- **Control de Acceso:** Prohibición estricta de inicios de sesión como root vía SSH.
 - Eliminación de cuentas anónimas en servicios de transferencia de archivos.
- **Uso obligatorio de protocolos cifrados** (reemplazar FTP por SFTP o HTTPS).
- **Seguridad de las Operaciones:** Gestión de vulnerabilidades técnicas mediante escaneos periódicos con herramientas como Nmap.

Políticas de Prevención de Pérdida de Datos (DLP)

- **Protección de Datos en Reposo:** Cifrado de la base de datos MariaDB y restricción de permisos a nivel de sistema de archivos (evitar el uso de 755 en archivos con credenciales).

- **Monitoreo de Exfiltración:** Implementación de alertas cuando se detecten descargas masivas desde el puerto de la base de datos o intentos de acceso a la tabla mysql.user por usuarios no autorizados.
- **Copias de Seguridad:** Mantener respaldos fuera de línea para garantizar la disponibilidad frente a ataques de borrado o cifrado.